

SİBER GÜVENLİK

201 HAZIRLIK PROJESİ: "Blueprint & The Watcher"

Blue Print & The Watcher

Bölüm A: Teori ve Mimari (Research and Logic)

Windows Mimarisi: Yetki Kimin Elinde?

Administrator vs. System: Administrator ve system windowsta sahip olunabilecek erişim yetkisi en fazla olan hesaplardır. Administrator hesabı yüksek yetkilere sahip kullanıcı hesabıdır ve kullanıcı dosyaları, uygulama yükleme ve ayarları değiştirme gibi yetkilere sahiptir. System hesabı ise windowsun işletim sistemi hesabıdır ve Administrator hesabının sahip olduğu yetkilere sahip olmanın yanında işletim sisteminin çekirdek bileşenleri, donanım ve kayıt defteri üzerinde tam kontrole sahiptir. Administrator yetkiniz olsa bile kullanıcıların şifrelerin tutulduğu SAM in veritabanına erişemezken System hesabı erişebilir. System yetkisi ile güvenlik yazılımlarını devre dışı bırakabilir ve içine kod yazabilirsiniz. Ayrıca System hesabıyla registry yani kayıt defteri gibi büyük veritabanına erişebilirsiniz bu farklarından dolayı Red Team operasyonlarında hedef daima System yetkisidir.

UAC (user account control): Windows ta yetkisiz erişimleri önlemek için genellikle uygulama veya yazılımların cihaz üzerinde yapabilecekleri değişikliklerin iznini yöneten sistemdir. Kullanıcı özellikle yeni bir yazılım veya uygulama yüklerken ekranda "Bu uygulamanın cihazınızda değişiklik yapmasına izin veriyor musunuz?" sorusuyla iznini alır. Peki arka planda nasıl çalışıyor , bakalım. Kullanıcı oturum açtığında windows kullanıcı için güvenlik ID si ve sahip olduğu yetkileri içeren bir güvenlik kartı, kimliği(security token) hazırlıyor. Windows kullanıcı etkinliklerinde security token a bakarak yapıp yapamayacağını belirliyor. UAC mantığında ise yönetici oturum açtığında 2 security token veriliyor biri yönetici kimliğiyle sistemde değişiklik yapmak için diğer ise standart kullanıcı faaliyetleri için . Bir uygulama sistem değişikliği istediğinde, AppInfo servisi devreye girerek kullanıcıdan "Güvenli Masaüstü" üzerinde onay alır ve ancak "Evet" denilirse yönetici token'ı sürece bağlar. UAC bypass, bir saldırganın Windows un güvendiği genelde kullanıcıdan onay alınmadan faaliyet gösteren araçlarla, uygulamalarla kayıt defterlerine kod ekleme ya da bazı programlara zararlı DDL dosyaları yükleme gibi yollarla düşük yetkiden yüksek yetkiye geçmesidir.

Windows Services: Windows servisi arka planda System yetkisiyle yani en yüksek yetkiyle çalışır. Windows servisleri bir dosyayı okurken eğer dosya adında boşuk varsa bu dosyayı bölerek okur yani dosya adı tam olarak algılayamaz örneğin boşluğa kadar olan kısmı okur ve bu isimde dosya var mı kontrol eder yoksa geri kalan kısmı okuyarak dosyayı bulmaya çalışır. Saldırganlardan bu zafiyetten faydalanarak kendi malware dosyasını asıl dosyanın bulunduğu klasöre asıl aranan dosyanın tam adını değil boşluğa kadar olan karakterleri girerek isimlendirir ve bu şekilde windowsa kendi zararlı dosyasını okutur ve genelde dosyası System yetkisiyle çalışır. Bu açığı dosya yolunu tırnak içine alarak engelleyebiliriz tırnak içine alınan bir dosya yolunda windows yolun tamamını okuyarak doğru dosyaya gider.

Mavi Takımın Gözü: Sessizliği Bozmak

SIEM/ EDR nedir?: SIEM ve EDR ağ güvenliğini sağlayan gelişmiş araçlardır. Event Viewer ise bilgisayardaki hareketleri kaydeden bir yapıdır. Büyük kurumlar windowstaki Event Viewer ile yetinmezler ve SIEM/EDR araçlarına ihtiyaç duyarlar çünkü olası bir saldırıda event viewer küçük hataları ve uyarıları da bildirdiği için asıl saldırıyı ayırt etmek ya da çok fazla bilgisayarın kontrol edildiği sistemde uyarı bulmak için teker teker bilgisayarları incelemek gerekir. SIEM ve EDR ise bu uyarıları ayırt eder, gerçekten saldırı olabilecek hareketleri bildirir ve gerekirse müdahale eder . Ayrıca saldırgan Event Viewer da kayıtlı etkinliklerini silebilirken SIEM/EDR araçları kullanıldığında loglar anlık olarak başka bir sunucuya gönderildiğinden silemez.

Gürültülü Araçlar: WinPeas veya Bloodhound gibi keşif araçları bir ağdaki güvenlik açıklarını tarayan yetkilendirme sistemini gösteren hizmet yapılandırma hataları kayıt defteri ve dosya izinleriyle yetki yükseltmeye neden olabilecek zaafiyetleri tararlar ancak bunların tespit edilmesi çok kolaydır bu yüzden Mavi Takım anında larm alır. Bu durumun birden fazla nedeni vardır: çok hızlı bir şekilde olağanın dışında yaparlar örneğin 1 saniyede 1000 dosya taraması yapılması gibi, çok fazla LDAP sorgusunda bulunması ,EDR gibi sistemlerin bu araçları tanıması gibi.

Bölüm B: Saha Operasyonu (Blueprint Fights)

Cephe 1: Sistemin Kalbi (Windows İşletim Sistemi)

Task manager (görev yöneticisi): Genel olarak uygulamaların , bilgisayarın detaylı (kullanıcılar, çalışma süresi , ram , , disk ve ağdaki tüketim gibi) özelliklerini gösteren ve kontrol etmemizi sağlayan araçtır. Anlık kaynak kullanımı, donanımla ilgili bilgiler sunabilen ;bir uygulamayı silmek , sekme geçişleri gibi birçok ayar yapabilen çok kapsamlı bir Windows süreç yöneticisidir.

Services(Servisler): Servisler arka planda çalışan özel hizmet uygulamasıdır. Servisler çalışır olsun veya olmasın bilgisayarda yer alan tüm servisleri listeler.

Registry (Kayıt Defteri):Sistem ayarları, donanım yapılandırmaları ve kullanıcı profillerinin tutulduğu Windows işletim sisteminin veri tabanıdır. Bilgisayarın her adımı için referans aldığı bu yapıdaki hatalı bir değişiklik, sistemin tamamen bozulmasına yol açabileceği için sadece çok yüksek yetkideki kişiler tarafından değiştirilebilir.

Windows Kayıt Defteri, sistemdeki tüm programların ve servislerin hangi yetkiyle çalışacağını belirleyen kayıtların tutulduğu yerdir. Eğer bu yapıda "Zayıf Yetkilendirme" (Weak Permissions) varsa, düşük yetkili bir kullanıcı olarak yüksek yetkiye sahip olabilirim . Bu durum, saldırganların kayıt defterindeki servis yollarını manipüle ederek zararlı kod satırlarını dosyalara eklemesine neden olabilir ve yetki yükseltmeme (Privilege Escalation) olanak tanır.

BÖLÜM C: İşletim Sistemi Keşfi (Local Recon Adımları)

Cephe 1: Kimlik ve Yetki Haritası

Sistemde ilk iş olarak whoami /user komutuyla kendi kimlik bilgilerimi ve yetkilerimi döktüm. SID numaramın sonundaki 1001 ibaresi, sistemde sonradan oluşturulmuş standart bir kullanıcı olduğumu; whoami /priv çıktısındaki neredeyse tüm kritik hakların "Disabled" olması ise yetkimin kısıtlı olduğunu gösterdi. net user komutuyla da nerelerde Administrator yetkim olduğunu görüntüledim

```
USER INFORMATION
-----

User Name          SID
=====
saniye-s-laptop\saniye S-1-5-21-3294706212-1065926731-28231462-1001

C:\Users\saniye>whoami/priv

PRIVILEGES INFORMATION
-----

Privilege Name      Description              State
=====
SeShutdownPrivilege Sistemi kapat           Disabled
SeChangeNotifyPrivilege Çapraz geçiş denetimini atla Enabled
SeUndockPrivilege   Bilgisayarı takma biriminden çıkar Disabled
SeIncreaseWorkingSetPrivilege İşlem çalışma kümesini artır Disabled
SeTimeZonePrivilege Saat dilimini değiştir  Disabled

C:\Users\saniye>net user[Saniye]
Bu komutun sözdizimi:

NET
[ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
  HELPMMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
  STATISTICS | STOP | TIME | USE | USER | VIEW ]

C:\Users\saniye>
```

Cephe 2:Servis ve Dosya Yolu Analizi

Spooler servisin inceledim ve BINARY_PATH_NAME kısmında boşuk bulunmadığını gözlemledim

```
C:\Users\saniye>sc qc Spooler
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        START_TYPE          : 2    AUTO_START
        ERROR_CONTROL        : 1    NORMAL
        BINARY_PATH_NAME     : C:\WINDOWS\System32\spoolsv.exe
        LOAD_ORDER_GROUP     : SpoolerGroup
        TAG                  : 0
        DISPLAY_NAME         : Yazdırma Biriktiricisi
        DEPENDENCIES          : RPCSS
                           : http
        SERVICE_START_NAME   : LocalSystem

C:\Users\saniye>
```

Cephe 3: Profesyonel Değerlendirme (Security Assesment)

Bulgular: Kendi bilgisayarımda yaptığım yerel keşif (Local Recon) sonucunda, sc qc ve reg query (Registry) sorgularıyla otomatik başlayan tüm servislerin dosya yollarını denetledim. Yapılan teknik analizde, servislerde tırnak işareti eksikliği olan ve aynı zamanda boşluk içeren (Unquoted Service Path zaafiyeti içeren) herhangi bir güvensiz dosya yoluna rastlamadım.

Sonuç: Sistemim, Windows servis yetki yükseltme (PrivEsc) zafiyetine karşı güvenli şekilde yapılandırılmıştır. Kullanıcı yetkilerim ve servis yolları, saldırganların sistemde System yetkisine erişmesini engelleyecek durumdadır, zaafiyet bulunmamaktadır.

Bölüm D: Mühendislik Vizyonu(Reflection)

1. "Yakalanmadan Yükselmek" (Evasion & LOLBAS Mantiğı): WinPEAS gibi dışarıdan getirilen araçlar, imzalanmamış ve gürültülü (noisy) yapıları nedeniyle EDR sistemleri tarafından kolayca engellenip alarm üretir. Bir Red Team uzmanı, bu engeli aşmak için Windows'un kendi içindeki güvenilir ve imzalı bileşenlerini kullanan LOLBAS yöntemine başvurur. certutil.exe veya bitsadmin.exe gibi araçlar, windows un güvendiği sistemlerdenmiş gibi davranır EDR, işletim sisteminin parçası olan bu meşru komutları tamamen engelleyemez ve dosya indirme, kod çalıştırma gibi işlemleri antivirüse takılmadan gerçekleştirir. Bu sayede hem diskte iz bırakmayan fileless (dosyasız) bir saldırı yürütülür hem de anomali skorunu düşük tutarak SOC ekibine yakalanma ihtimalini epey düşürürler.
2. Çözüm Üretmek (Mitigation & Hardening):Unquoted Service Path zafiyetini bitirmek için servis yolunu mutlaka çift tırnak içine almalı ve Windows'un boşluklu dizinleri yanlış yorumlamasını engellemelisiniz. Weak Registry Permissions (zayıf yetkilendirilmiş kayıt defteri) tarafında ise User grubunun servis anahtarları üzerindeki yazma yetkisini iptal etmeli, izinleri sadece SYSTEM ve Administrators ile sınırlandırmalıdır. Dosya izinleri denetlenmelidir. Bu sıkılaştırma adımları atılmadığı sürece, saldırganın System yetkisine ulaşmasını EDR ler durduramayabilir.